

G-CAF

GovDigital Composable Architecture Framework

Volume 7

Assessments & Compliance

v2.0

Table of Contents

Chapter 1 Platform Assessment Framework

8-dimension, 134-criteria methodology

Chapter 2 Scoring Rubric

Detailed 0/1/2 scoring guidance per criterion

Chapter 3 Assessment Questionnaire

134 criteria across 8 dimensions

Chapter 4 Gap Analysis & Remediation

Templates for gap identification and roadmap planning

Chapter 5 Reference Architecture Compliance

RA-specific assessments inheriting from base

Chapter 6 DevSecOps Maturity Model

L0–L4 maturity across DevSecOps capabilities

Chapter 7 Governance Maturity Extension

Deep governance decision-level assessment

Chapter 8 COBIT 2019 Mapping

40 COBIT objectives mapped to G-CAF controls

Chapter 9 UAE IA Standard Mapping

108 controls across 12 domains mapped to G-CAF

Chapter 10 MITRE ATLAS Mapping

AI adversarial techniques mapped to G-CAF controls

Chapter 11 UAE TPSP Mapping

29 third-party security modules mapped to G-CAF

Chapter 1

Platform Assessment Framework

The G-CAF Assessment Framework provides a systematic methodology for assessing any platform against G-CAF standards. It follows a 5-step process: Scope → Assess → Score → Gap Analysis → Roadmap.

8 Assessment Dimensions

Dimension	G-CAF Layer	Weight	Criteria	Description
Architecture	Capability Tier	20%	23	PBC design, composition, modularity
Integration	Platform Tier (GovDX)	15%	22	API design, event-driven patterns
Data	Platform Tier (Data Fabric)	15%	21	Data management, quality, governance
Domain Model	Capability Tier	10%	12	DDD alignment, bounded contexts
Security	Cross-cutting	15%	16	Security controls, compliance
Operations	Operations Frame	10%	16	Observability, reliability, sustainability
Governance	Cross-cutting	10%	18	ARB alignment, documentation, decisions
Experience	Experience Tier	5%	13	Composition, citizen experience

5-Level Maturity Model

Level	Name	Score	Description
1	Initial	0–20%	Ad-hoc, undocumented, inconsistent
2	Developing	21–40%	Basic practices, partially documented
3	Defined	41–60%	Standardized, documented, repeatable
4	Managed	61–80%	Measured, controlled, optimizing
5	Optimizing	81–100%	Continuous improvement, industry-leading

Chapter 2

Scoring Rubric

Each criterion is scored on a 3-point scale ensuring consistent, objective assessments across platforms and assessors.

Scoring Scale

Score	Rating	Description
0	Not Implemented	No evidence, not applicable, or actively violating
1	Partially Implemented	Some evidence, inconsistent, or incomplete
2	Fully Implemented	Complete evidence, consistent, and mature

Architecture Dimension — Sample Criteria

Criterion	Score 0	Score 1	Score 2
PBC Identification	No capability-to-PBC mapping	Some capabilities mapped; mapping incomplete	All capabilities mapped; catalog maintained
PBC Boundaries	No defined boundaries; shared databases	Some boundaries; some shared databases	Clear boundaries; each PBC owns data
PBC Sizing	Monolith (>100K LOC) or nanoservices (<1K)	Size varies significantly	Appropriately sized (10K–50K LOC)
Single Responsibility	Multiple unrelated responsibilities	Primary responsibility clear; scope unclear	One clear documented responsibility
Loose Coupling	Tight coupling; sync calls; shared state	Mix of sync and async; some queues	Loose coupling via APIs/events; independent
Interface Stability	Frequent breaks; no versioning	Some versioning; quarterly breaks	Semantic versioning; 6+ month deprecation

Chapter 3

Assessment Questionnaire

The questionnaire covers **134 criteria** across 8 dimensions. All criteria are derived from the central requirements registry.

Criteria Distribution

Dimension	Weight	Criteria Count	Sub-Categories
Architecture	20%	23	PBC Design (8), Composition (6), Patterns (5), NS Compliance (4)
Integration	15%	22	API Standards (8), Event Standards (6), Gateway (4), Schema (4)
Data	15%	21	Classification (5), Ownership (4), Quality (5), Residency (3), Sharing (4)
Domain Model	10%	12	Bounded Contexts (4), Aggregates (3), Events (3), Language (2)
Security	15%	16	Authentication (4), Encryption (3), Zero Trust (3), DevSecOps (4), Public-Facing (2)
Operations	10%	16	Observability (5), Capacity (3), BCM (4), Secrets (2), SecOps (2)
Governance	10%	18	Bodies (3), Contracts (4), Gateways (4), Classifications (3), Decisions (4)
Experience	5%	13	Portals (3), Channels (3), Composition (4), Accessibility (3)

Interpretation

Overall %	Maturity Level	Status
0–20%	Level 1	Initial — significant gaps requiring immediate attention
21–40%	Level 2	Developing — major improvements needed
41–60%	Level 3	Defined — on track, continue progress
61–80%	Level 4	Managed — strong compliance, optimize
81–100%	Level 5	Optimizing — industry-leading

Chapter 4

Gap Analysis & Remediation

Gap Status Levels

Gap %	Status	Action Required
0–20%	Critical	Immediate remediation required
21–40%	High	Priority remediation within 1–3 months
41–60%	Medium	Planned remediation within 3–6 months
61–80%	Low	Optimization opportunity within 6–12 months
81–100%	Target	Maintain and continuously improve

Remediation Roadmap Structure

Each remediation roadmap includes: current vs. target maturity state, quarterly score trajectory per dimension, strategic initiatives with gap mappings (ID, priority, duration, budget), detailed initiative plans with milestones and success criteria, and dependency tracking between initiatives.

Typical Initiative Categories

Priority	Initiative Example	Typical Duration	Focus
P1 Critical	Security Hardening	3 months	Close critical security gaps
P1 Critical	API Standardization	4 months	Align APIs to GovDX standards
P2 Important	Observability Platform	3 months	Full-stack monitoring
P2 Important	Data Governance	6 months	Classification, quality, ownership
P3 Desirable	PBC Refactoring	6 months	Decompose monoliths into PBCs
P3 Desirable	Documentation	3 months	Architecture and contract documentation

Chapter 5

Reference Architecture Compliance

RA-specific compliance assessments inherit the generic 134-criteria assessment and extend it with RA-specific requirements.

Inheritance Model

Assessment	Base Criteria	RA Additions	Total
Generic Assessment	134	—	134
REF-001 OneHub	134	24	158
REF-002 GovData Platform	134	30	164

Combined Score Formula

Combined Score = (Generic Score x 0.70) + (RA-Specific Score x 0.30). Complete the generic assessment first, then apply RA overrides (stricter requirements for some criteria), then score RA additions, and finally calculate the combined maturity level.

Chapter 6

DevSecOps Maturity Model

5-level maturity model for assessing security integration within development and operations practices.

Maturity Levels

Level	Name	Description
L0	Initial	No formal DevSecOps; security is afterthought
L1	Developing	Ad-hoc security; manual processes, reactive
L2	Standardized	Defined processes; partial automation; security gates exist but not universal
L3	Integrated	Security embedded in all pipelines; automated, consistent, measurable
L4	Optimizing	Security is competitive advantage; continuous improvement, innovation

Capability Areas

Capability	L0	L2	L4
Culture	Security team only	Champions program exists	Security-first mindset; proactive hunting
SAST/DAST	No scanning	Selected projects scanned	All code scanned; auto-block on critical
SCA	No dependency scanning	Manual dependency review	Automated SCA in all pipelines
IaC Security	No IaC scanning	Some IaC templates scanned	All IaC validated pre-deploy
Secrets	Hardcoded secrets	Vault for some projects	All secrets in vault; auto-rotation
Container	No container security	Basic image scanning	Signed images; runtime protection

Chapter 7

Governance Maturity Extension

This extension deepens the Governance dimension of the assessment framework with decision-level maturity criteria.

Governance Decision Categories

Category	Decisions	G-CAF Owner	Weight
Strategic Governance	Framework Direction, Investment Mix, Risk Appetite	ARB	30%
Operational Governance	PBC Architecture, Contracts, Gateways	DDA	40%
Lifecycle Governance	Retirement, Exceptions, Compliance	ARB/DDA	30%

Each governance decision is assessed independently across the 5 maturity levels, from ad-hoc (Level 1) to continuously optimized (Level 5). COBIT-DEMO Level 0 (Incomplete) maps to G-CAF Level 1 sub-category "Not Started".

Chapter 8

COBIT 2019 Mapping

G-CAF governance mechanisms mapped to all 40 COBIT 2019 objectives across 5 domains.

COBIT Domain Coverage

Domain	Code	Objectives	G-CAF Coverage
Evaluate, Direct and Monitor	EDM	5	90% (4 Full, 1 Partial)
Align, Plan and Organize	APO	14	86% (10 Full, 4 Partial)
Build, Acquire and Implement	BAI	11	~85%
Deliver, Service and Support	DSS	6	~80%
Monitor, Evaluate and Assess	MEA	4	~85%

Key Mappings

COBIT Objective	G-CAF Module	Evidence
EDM01 Governance Framework	G-CAF-042 (Governance Decisions)	Framework direction in GD-01
EDM02 Benefits Delivery	G-CAF-043 (Investment)	Investment mix, program decisions
APO03 Enterprise Architecture	G-CAF-020, G-CAF-102	Framework overview, Capability Tier
APO13 Managed Security	G-CAF-070 (Security Contract)	Security contract with 90+ requirements
APO14 Managed Data	G-CAF-071 (Data Contract)	Data contract, ownership model
BAI03 Solutions Build	G-CAF-091 (Design Gateway)	Architecture review, contract validation

Chapter 9

UAE IA Standard Mapping

Maps G-CAF controls (including AI Security Extension) to the UAE Information Assurance Standard v2 — 108 controls across 12 domains.

Domain Coverage Summary

Domain	Controls	Coverage	Highlights
1. Security Governance	~12	92%	11 Full, 1 Partial; policies, risk management, metrics
2. Asset Management	~8	100%	Includes AI/ML asset inventory (AIBOM)
3. Human Resource Security	~6	~90%	Training guide, AI security training
4. Physical & Environmental	~8	~70%	Limited — out of G-CAF scope
5. Communications & Ops	~14	~85%	Change management, malware, capacity
6. Access Control	~10	100%	Zero Trust, RBAC/ABAC, MFA
7. IS Acquisition & Development	~12	100%	SDLC security, DevSecOps, SAST/DAST
8. Supplier Relationships	~8	100%	Vendor compliance, TPSP alignment
9. Incident Management	~8	~90%	SOC, SIEM, incident response runbooks
10. Business Continuity	~6	100%	DR, backup, RTO/RPO by criticality
11. Compliance	~6	~85%	Audit framework, policy adherence
12. Cloud & AI Security	~10	100%	Cloud governance, AI-specific controls (v2.1)

Chapter 10

MITRE ATLAS Mapping

Maps G-CAF controls to MITRE ATLAS — the AI/ML-specific adversarial threat framework. Covers all 12 ATLAS tactics with 100% coverage.

ATLAS Tactic Coverage

Tactic	Key Techniques	G-CAF Controls	Coverage
Reconnaissance	ML model discovery, fingerprinting	G-CAF-AIS-103, G-CAF-110	Full
Resource Development	Acquire ML artifacts, adversarial supply	Supply chain, AIBOM	Full
Initial Access	Supply chain compromise, valid credentials	G-CAF-AIS-103, Supply chain security	Full
ML Attack Staging	Proxy model, adversarial crafting	G-CAF-AIS-102, AIS-103	Full
Execution	Adversarial inputs, prompt injection	G-CAF-AIS-102 (direct + indirect)	Full
Persistence	Backdoor ML model, poisoned training data	G-CAF-AIS-106, AIS-101	Full
Defense Evasion	Input perturbation, concept drift	G-CAF-AIS-102, AIS-105	Full
Discovery	Model reverse engineering, data disclosure	G-CAF-AIS-103, AIS-104	Full
Exfiltration	Model extraction, membership inference	G-CAF-AIS-103, AIS-104	Full
Impact	Model degradation, denial of ML service	G-CAF-AIS-105, AIS-107	Full

Chapter 11

UAE TPSP Mapping

Maps G-CAF controls to the UAE National Third Party Security Policy — 29 modules across 10 domains.

TPSP Domain Coverage

Domain	Modules	Coverage	Key G-CAF Modules
Governance	2	100%	Procurement governance, vendor compliance (88 reqs)
Risk Management	4	100%	PBC Catalog vendor fields, compliance tiers (1–4)
Supplier Assessment	2	100%	Vendor Security Assessment Questionnaire
SW/HW Supply Chain	6	100%	SBOM/AIBOM requirements, container signing
Contracts & Legal	3	100%	Vendor contract template, security contract
Monitoring & Audit	3	100%	Certification process, continuous monitoring
Resilience	3	100%	BCM, incident response, vendor exit strategy
Implementation	3	Partial	National-level coordination out of scope

Key TPSP Requirements Addressed

Requirement	G-CAF Solution
Maintain vendor inventory with services, PBCs, catalog vendor fields	PBC Catalog vendor fields + vendor registry
Classify vendors by risk level	Compliance tiers (Tier 1–4) based on criticality
SBOM for all software components	SBOM requirements in Developer Platform; AIBOM for AI
Periodic re-assessment of vendor risks	Annual attestation; certification renewal process
Incident response coordination with vendors	BCM contract; incident communication protocol
Vendor exit strategy with data destruction	Retirement gateway; vendor exit strategy document